

Research Project

Programme: National PhD in Artificial Intelligence — Security & Cybersecurity area (Sapienza Rome + CNR consortium; PNRR national programme) **Working title:** *Detecting Poisoning and Backdoors in Fine-Tuned Transformers, and Governing Them After Deployment* **Applicant:** Nauval Zulfikar — MSc Business Analytics (Aston University, 2024, First Class 1:1)

Note: section structure and length to be reconciled with the official call template — verify on call PDF.

1. Motivation

Organisations increasingly adapt pretrained transformers and large language models (LLMs) to their own data and then run them as long-lived, deployed systems — often inside regulated, adversarial settings. My professional starting point was exactly such a setting: as Lead Data Scientist at a licensed bank, I was responsible not for building a model once, but for keeping deployed NLP and risk-scoring models trustworthy over time — running validation cycles, monitoring model staleness, and producing audit-grade documentation that satisfied regulatory and audit frameworks. That work made one thing concrete: the security of an AI system is not decided at training time, it is decided across its deployed lifetime, where the threat surface (poisoned fine-tuning data, hidden backdoors, distribution drift, adversarial inputs) is largest and least observable. This project brings that operational concern into a rigorous security research agenda.

2. Threat model and gap

When a transformer is fine-tuned on externally sourced or user-contributed text, an adversary can (a) **poison** the fine-tuning set so the model's behaviour degrades or shifts on targeted inputs, and (b) plant a **backdoor** — a trigger pattern that flips the model's output while leaving held-out accuracy intact, making the compromise invisible to standard evaluation. The literature offers strong attacks and several point defences, but two gaps matter for a *cybersecurity* programme:

1. **Detection under realistic constraints.** Many defences assume access to clean reference data or to the poisoned set itself. Operators rarely have either. We need detectors that work from the fine-tuned model and ordinary monitoring signals alone.
2. **No bridge to governance.** Backdoor/poisoning detection is studied as an offline ML problem, disconnected from the audit, validation, and continuous-monitoring machinery that actually governs deployed models. A detection result that cannot be turned into an auditable, reproducible control is of limited use to a regulated operator.

3. Research questions

- **RQ1** — Can poisoning and backdoor triggers in fine-tuned transformers be detected from the model and its inference-time behaviour alone, without clean reference data?
- **RQ2** — Which post-deployment monitoring signals (representation drift, calibration shifts, trigger-sensitivity probes, staleness indicators) reliably flag a compromised model in production?
- **RQ3** — How can such detection be packaged as an *auditable, reproducible control* — an evidence trail a regulator or security auditor can verify?

4. Approach and methodology

The project is empirical and reproducibility-first, mirroring how I already build systems (controlled sweeps, traceable fallbacks, ablations).

- **Phase 1 — Threat reconstruction (Year 1).** Build a controlled benchmark by fine-tuning transformer classifiers (e.g. DeBERTa-v3, a family I have fine-tuned end-to-end) under known data-poisoning and backdoor injection regimes. Vary trigger type, poison rate, and task. This gives ground-truth-labelled compromised vs. clean models — the substrate every later phase is measured against.
- **Phase 2 — Reference-free detection (Years 1–2).** Develop detectors operating on the model alone: representation-space anomaly analysis, trigger-reverse-engineering, sensitivity/consistency probing, and calibration diagnostics. Evaluate with held-out attacks and proper ablations, reporting detection rate, false-positive cost, and compute budget.
- **Phase 3 — From detection to governance (Years 2–3).** Integrate the strongest detectors into a continuous post-deployment monitoring loop that emits auditable evidence: versioned model fingerprints, drift/staleness alarms, and a traceable decision log — translating my bank-era validation/documentation practice into a security control. Where an LLM is deployed *agentically* (tool-calling, retrieval), extend monitoring to the action layer, using a traceable rule-based fallback pattern (as in my LLM-Shipper-Profiles RAG system) so that unsafe agent behaviour is both detectable and reversible.

Evaluation is anchored to public attack/defence baselines and released as reproducible code, consistent with my prior controlled-experiment work (e.g. a 450-run behavioural parameter sweep with literature-anchored results).

5. Expected contributions

1. An open, labelled benchmark of poisoned/backdoored fine-tuned transformers across trigger and poison-rate regimes.

2. Reference-free detectors validated under realistic operator constraints, with honest false-positive and compute accounting.
3. A governance bridge — a reproducible, audit-grade monitoring/control specification turning detection into verifiable security evidence for deployed (including agentic) models.

6. Fit with the Security & Cybersecurity area

The area sits precisely at the intersection of AI and cybersecurity, where my profile is strongest: hands-on transformer fine-tuning and RAG (DeBERTa-v3 dissertation, gpt-4o-mini RAG with traceable fallback) on the technical side, and **governance of deployed ML under regulated, audited, adversarial conditions** — model validation, reliability, staleness monitoring, audit-grade documentation at a licensed bank — on the operational side. That combination is rare and directly serves a national programme whose cyber slots are co-funded by the national cyber agency: the goal is not only to attack and defend models in the lab, but to make their security *operable and auditable* in deployment. The Sapienza + CNR research environment, with its security and trustworthy-AI strengths, is where I want to formalise and deepen this agenda.

All claims trace to the candidate's verified profile. Specific Sapienza/CNR/ACN supervisors and groups are intentionally not named pending confirmation — [TODO: verify with user] before naming a host group.